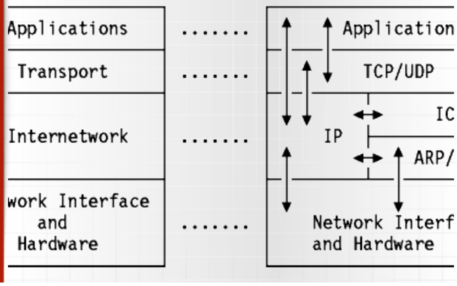
Cybersecurity
Security of Internet Protocols



Cybersecurity

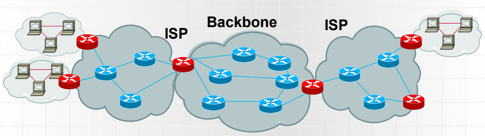
Agenda

- Network communication related attacks
- Examples of Attacks
  - Eavesdropping
  - Spoofing
  - Hijacking
  - (D)DoS
  - Heartbleed

Cybersecurity

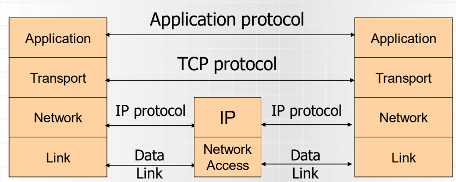
Internet Infrastructure

- Local and interdomain routing
  - TCP/IP for routing and messaging
  - BGP for routing announcements
- Domain Name System
  - Find IP address from symbolic name (www.pwr.edu.pl)



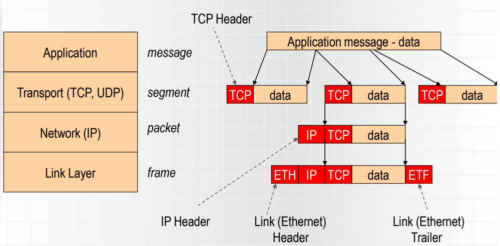
Cybersecurity

TCP Protocol Stack



Cybersecurity

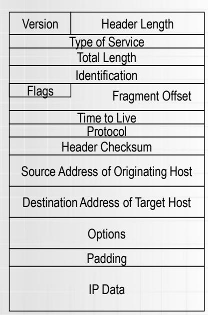
Data Formats



Cybersecurity

Internet Protocol (IP)

- Connectionless
  - Unreliable
  - Best effort
- Notes:
  - src and dest **ports** not parts of IP hdr



Cybersecurity

IP Protocol Functions (Summary)

- Routing
  - IP host knows location of router (gateway)
  - IP gateway must know route to other networks
- Fragmentation and reassembly
  - If max-packet-size less than the user-data-size
- Error reporting
  - ICMP packet to source if packet is dropped
- TTL field: decremented after every hop
  - Packet dropped if TTL=0. Prevents infinite loops.

Cybersecurity

Problem:no src IP authentication

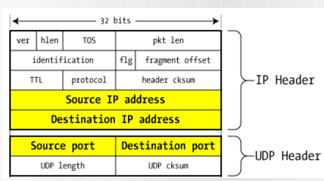
- Client is trusted to embed correct source IP
  - Easy to override using raw sockets
  - **Libnet**: a library for formatting raw packets with arbitrary IP headers
- Anyone who owns their machine can send packets with arbitrary source IP
  - … response will be sent back to forged source IP
- Implications:
  - Anonymous DoS attacks;
  - Anonymous infection attacks (e.g. slammer worm)

Cybersecurity

User Datagram Protocol

(protocol=17)

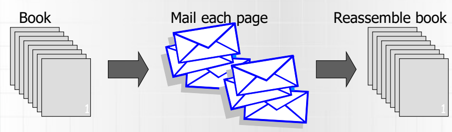
- Unreliable transport on top of IP:
  - No acknowledgment
  - No congestion control
  - No message continuation



Cybersecurity

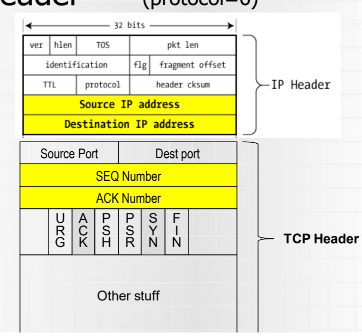
Transmission Control Protocol

- Connection-oriented, preserves order
  - Sender
    - Break data into packets
    - Attach packet numbers
  - Receiver
    - Acknowledge receipt; lost packets are resent
    - Reassemble packets in correct order



Cybersecurity

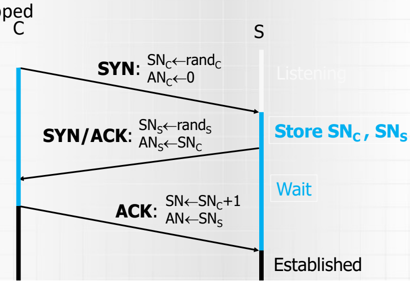
TCP Header (protocol=6)



Cybersecurity

Review: TCP Handshake

- Received packets with SN too far out of window are dropped



Cybersecurity

Basic Security Problems

1. Network packets pass by untrusted hosts
   - Eavesdropping, packet sniffing
   - Especially easy when attacker controls a machine close to victim
2. TCP state can be easy to guess
   - Enables spoofing and session hijacking
3. Denial of Service (DoS) vulnerabilities
   - DDoS lecture

Cybersecurity

Protocol Failures

- TCP/IP assumes that all nodes implement protocols faithfully
- E.g., TCP includes a mechanism that asks a sender node to slow down if the network is congested
  - An attacker could just ignore these requests
- Some implementations do not check whether a packet is well formatted
  - E.g., the value in the packet’s length field could be smaller than the packet’s actual length, making buffer overflow possible
  - Potentially disastrous if all implementations are from the same vendor or based on the same code base
- Protocols can be very complex, behavior in rare cases might not be (uniquely) defined
- Some protocols include broken security mechanisms
  - WEP (see later)

Cybersecurity

Eavesdropping and Wiretapping

- Owner of node can always monitor communication flowing through node
  - Eavesdropping or passive wiretapping
  - Active wiretapping involves modification or fabrication of communication
- Can also eavesdrop while communication is flowing across a link
  - Degree of vulnerability depends on type of communication medium
- It is wise to assume that your communication is monitored

Cybersecurity

Communication Media

- WiFi
  - Can be easily intercepted by anyone with a Wi-Fi-capable (mobile) device
    - Don’t need additional hardware
  - Kilometers away using a directed antenna
  - WiFi related other security problems
    - walls help against random devices being connected to a wired network, but are (nearly) useless in case of wireless network
    - some additional authentication mechanism is needed to defend against free riders

Cybersecurity

Misdelivered Information

- Local Area Network (LAN)
  - Technical reasons might cause a packet to be sent to multiple nodes, not only to the intended receiver
  - By default, a network card ignores wrongly delivered packets
  - An attacker can change this and use a packet sniffer to capture these packets
- Email
  - Wrongly addressed emails, inadvertent Reply-To-All

Cybersecurity

Identity theft

- Impersonate a person by stealing his/her password
  - Guessing attack
  - Exploit default passwords that have not been changed
  - Sniff password (or information about it) while it is being transmitted between two nodes
  - Social engineering

Cybersecurity

Simple spoofing example

- Say Bob trusts Alice (e.g. through /etc/hosts.equiv)

- Say also Alice is down (e.g. turned off)
- Say Mallory is on the LAN
- Mallory only needs to set his IP address to be Alice's address
- Bob will believe Mallory is Alice

Cybersecurity

Another spoofing example

- Say Bob trusts Alice (e.g. through some type of auth.)

- Say this time Alice is alive and Mallory is on the LAN
- Mallory tries to open an connection

Mallory → Bob: SYN(ISN_A) # hi
Bob → Alice: ACK($ISN_A + 1$), SYN(ISN_B) # welcome
Alice → Bob: RST # wasn't me!

- Alice will tear down the connection

Cybersecurity

Another spoofing example

- However Mallory can denial-of-service Alice

Mallory → Alice: Denial-of-Service # bye bye
Mallory → Bob: SYN(ISN_A) # hi
Bob → Alice: ACK($ISN_A + 1$), SYN(ISN_B) # welcome
Mallory → Bob: ACK($ISN_B + 1$), PSH(DATA) # thanks

- Mallory can successfully complete the connection

Cybersecurity

Spoofing

- An object (node, person, URL, Web page, email, WiFi access point,...) masquerades as another one
- URL spoofing (Social eng.)
  - Exploit typos: www.pwr.edi.pl
  - Exploit ambiguities: www.eportal.pwr.edu.pl or www.e-portal.pwr.edu.pl?
  - Exploit similarities: www.pwrl.edu.pl
- Web page spoofing and URL spoofing are used in Phishing attacks
- "Evil Twin" attack for WiFi access points
- Spoofing is also used in session hijacking and man-in-the-middle attacks

Cybersecurity

Session Hijacking

- TCP protocol sets up state at sender and receiver end nodes and uses this state while exchanging packets
  - e.g., sequence numbers for detecting lost packets
  - attacker can hijack such a session and masquerade as one of the endpoints
- Web servers have client keep a little piece of data ("cookie") to re-identify client for future visits
  - Attacker can sniff or steal cookie and masquerade as client
- Man-in-the-middle attacks are similar; attacker becomes stealth intermediate node, not end node

Cybersecurity

Traffic Flow Analysis

- Sometimes, even the existence of communication between two parties is sensitive and should be hidden
  - Whistleblower
  - Military environments
  - Two CEOs
- TCP/IP has each packet include unique addresses for the packet's sender and receiver end nodes
- Attacker can learn these by sniffing packets

Cybersecurity

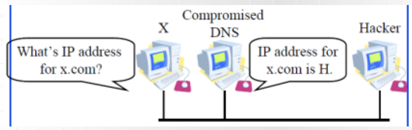
Integrity Attacks

- Attacker can modify packets while they are being transmitted
  - Change payload of packet
  - Change address of sender or receiver end node
  - Replay previously seen packets
  - Delete or create packets
- Line noise, network congestion, or software errors could also cause these problems
  - TCP/IP will likely detect environmental problems, but fail in the presence of an active attacker
  - How in the case of TCP's checksumming mechanism?

Cybersecurity

Integrity Attacks

- DNS cache poisoning
  - Domain Name System maps hostnames (www.pwr.edu.pl) to numerical addresses (156.17.70.161), as stored in packets
  - Attacker can create wrong mappings



Cybersecurity

Web Site Vulnerabilities

- Accessing a URL has a web server return HTML code
  - Tells browser how to display web page and how to interact with web server
  - Attacker can examine this code and find vulnerabilities
- Attacker crafts malicious URL and sends it to web server
  - to exploit a buffer overflow
  - to invoke a shell or some other program
  - to feed malicious input parameters to a server-side script
  - to access sensitive files
    - E.g., by including "../" in a URL or by composing URLs different from the "allowed ones" in the HTML code

Cybersecurity

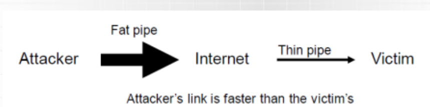
Denial of Service principles

- Find a resource (any resource) and use it up
  - Bandwidth
  - CPU or router processing ability
  - Memory, disk space
  - File descriptors, sockets (or other OS resources)
  - Cognitive limits of humans
- Own as many attackers as possible
  or
- Find amplifiers
- Choose amplifiers with abundant bandwidth

Cybersecurity

Denial of Service (DoS)

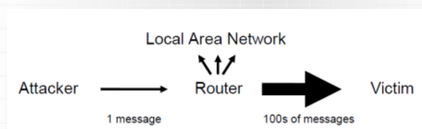
- Ping flood
  - Node receiving a ping packet is expected to generate a reply
  - Attacker could overload victim
  - Different from "ping of death", which is a malformatted ping packet that crashes victim's computer



Cybersecurity

Denial of Service (DoS)

- Smurf attack
  - Spoof address of sender end node in ping packet by setting it to victim's address
  - Broadcast ping packet to all nodes in a LAN



Cybersecurity

Denial of Service

- Exploit knowledge of implementation details about a node to make node perform poorly
- SYN flood
  - TCP initializes state by having the two end nodes exchange three packets (SYN, SYN-ACK, ACK)
  - Server queues SYN from client and removes it when corresponding ACK is received
  - Attacker sends many SYNs, but no ACKs
- Send packet fragments that cannot be reassembled properly
- Craft packets such that they are all hashed into the same bucket in a hash table

Cybersecurity

Denial of Service

- Black hole attack
  - Routing of packets in the Internet is based on a distributed protocol
  - Each router informs other routers of its cost to reach a set of destinations
  - Malicious router announces low cost for victim destination and discards any traffic destined for victim
  - Has also happened because of router misconfiguration
- DNS attacks
  - DNS cache poisoning can lead to packets being routed to the wrong host

Cybersecurity

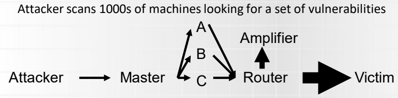
Distributed Denial of Service

- If there is only a single attacking machine, it might be possible to identify the machine and to have routers discard its traffic
- Difficult if there are lots of attacking machines
- Most might participate without knowledge of their owners
  - Attacker breaks into machines using Trojan, buffer overflow,… and installs malicious software
  - Machine becomes a zombie/bot and waits for attack command from attacker
  - A network of bots is called a botnet
  - How would you turn off a botnet?

Cybersecurity

Distributed Denial of Service

- Attacker scans 1000s of machines looking for a set of vulnerabilities



Attack constellation

- Script scans hundreds of machines that have a problem and installs a drone waiting for time and attack commands
- Modern features of DDOS attack tools
  - Anonymous encrypted one-way stealth protocols
  - Internet Relay Chat (IRC) command and control
  - Auto-update

Cybersecurity

Botnets

- Botnets are very sophisticated and include
  - Virus/worm/trojan for propagation based on multiple exploits
  - Stealthiness to hide from owner of computer
  - Code morphing to make detection difficult
  - Bot usable for different attacks (spam, DDoS,…)
  - Distributed, dynamic & redundant control infrastructure
- Earlier worms (Nimda, slammer) were written by hackers for fame with the goal to spread worm as fast as possible
  - slammer infected 75,000 hosts in 10 minutes
  - Caused disruption and helped detection

Cybersecurity

Botnets

- Botnets are controlled by hackers looking for profit, which rent them out
  - Criminal organizations
- Spread more slowly, infected machine might lie dormant for weeks
- Eg. Storm Worm botnet - expected to include millions of machines, its processing power likely makes it the world's biggest supercomputer

Cybersecurity

Heartbleed

RFC6520 defines SSL Heartbeats - What are they?

1. SSL Heartbeats are used to keep a connection alive without the need to constantly renegotiate the SSL session.

2. Used in MTU path discovery

Why is this a problem? Heartbeat requests can be sent WITHOUT authentication to the server.

Cybersecurity

Heartbleed

Security in Computer Network

Security of Internet Protoclols